

Billy (BK) Rios » Firefox File Handling Woes

Billy (BK) Rios » Firefox File Handling Woes - Author not stated, xs-sniper.com.

- Published: date not stated
- Original: <<http://xs-sniper.com/blog/2007/09/01/firefox-file-handling-woes/>>
- Preserved from: <http://xs-sniper.com/blog/2007/09/01/firefox-file-handling-woes/> (stored) on 2026-08-06
- Capture timestamp: 20160327061346
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Billy (BK) Rios » Firefox File Handling Woes

Saturday, September 1st, 2007

Firefox File Handling Woes

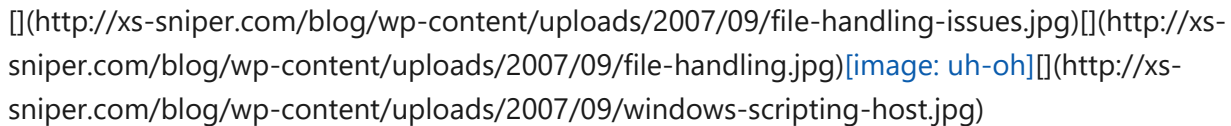
[(<http://xs-sniper.com/blog/wp-content/uploads/2007/09/file-handling.jpg>)]It seems recent **URI remote command execution bugs** in Firefox have long been forgotten. Mozilla put out a patch in a lightning fast manner, probably spurring on bravado like the **"10 Fucking Days!"** claim overheard at Black hat USA. Let's take a closer look at the vulnerability, starting with an interesting piece of the description provided in **MFSA2007-27**:

"...Further investigation by Secunia showed that a % not followed by a valid two-digit hexadecimal number also triggered the problem for the affected protocols. The Firefox and Thunderbird 2.0.0.6 releases contain fixes that prevent the original demonstrations of this variant, but it is still possible to launch a file type handler based on extension rather than the registered protocol handler. A way to exploit a common handler with a single unexpected URI as an argument may yet be found. Since this handling is a property of the Windows Shell API this variant appears to affect other internet-enabled applications that pass these URIs to the Windows Shell."

Well, to make a long story short, Nate and I have discovered a way to "...exploit a common handler with a single unexpected URI..." Once again, these URI payloads can be passed by the mailto, nntp, news, and snews URIs, allowing us to pass the payload without any user interaction. So, it seems that although the conditions which allowed for remote command execution in Firefox 2.0.0.5 have been addressed

with a security patch, the underlying file type handling issues which are truly the heart of the issue have NOT been addressed.

We contacted Mozilla a while ago about the issue and they are working on it. We're going to refrain from giving out the exact details of how this particular issue is executed (based mainly on the efforts and conversations we've had with Jesse Ruderman), but we'll include a screenshot of a payload in action. In the screenshot below, we use the mailto URI, which passes the URI to the Windows File Handler, which calls the appropriate program (in this case Windows Scripting Host), which in turn calls our attacker controlled file. We've purposely pointed the Windows Scripting Host to a file that doesn't exist as the error message allows the user to see that WSH is using the URI passed from Firefox.

The image is a placeholder for a screenshot. The alt text indicates it is a screenshot of a Windows error message, likely related to the Windows Scripting Host (WSH) and a mailto URI, as described in the text above.

Posted by xssniper | Filed in [Security](#)

Please leave a Comment

Archived from <http://xs-sniper.com/blog/2007/09/01/firefox-file-handling-woes/>. Rendered offline from the local Markdown copy.